

Comprendre la Conformité Sémantique (RGPD Art. 32)

Ce guide démystifie l'intégration de la conformité réglementaire dans un graphe de connaissances de sécurité (SOC). Conçu pour les néophytes, il explique comment lier l'architecture technique aux obligations légales sans complexité superflue.

1. Le Défi : Du Texte Juridique au Graphe de Sécurité

Dans un système classique, la conformité est un document Word ou PDF statique que l'on oublie dans un tiroir. Dans notre framework **DKG-CyberSec**, la règle juridique (le RGPD) devient un objet vivant connecté au réseau.



L'Idee Clé : Le règlement n'est pas "lu" en direct par une intelligence artificielle lourde. Il est transformé en *triplets sémantiques* (Sujet → Prédicat → Objet) qui viennent s'aligner directement sur le vocabulaire technique de notre infrastructure.

2. Quel est le rôle réel de la TBox et de l'ABox ?

Pour comprendre comment le rapprochement s'opère, il faut distinguer les deux piliers de notre base de connaissances :



La TBox (Le Dictionnaire)

Définit le "vocabulaire" et les concepts : Qu'est-ce qu'un actif ? Qu'est-ce qu'une vulnérabilité ? Quelles sont les exigences de sécurité fondamentales ?



L'ABox (La Réalité du Foyer)

Contient les "instances concrètes" : Mon ordinateur personnel, l'adresse IP 192 . 168 . 1 . 50, le port 22 ouvert, ou la CVE détectée sur un service.

Le rapprochement ne se fait pas par un simple mot-clé textuel, mais par un **alignement logique** : le concept normatif s'accouple aux classes de la TBox pour auditer les faiblesses physiques recensées dans l'ABox.

Mécanique du Rapprochement & Sobriété

3. Comment se concrétise la Règle RGPD ?

L'Article 32 du RGPD impose la mise en œuvre de *mesures techniques et organisationnelles appropriées*. Dans notre système, cette exigence est modélisée dans un sous-ensemble Turtle (`abox_compliance_standards_clear.ttl`):

Sujet (Le Concept)	Prédicat (La Relation)	Objet (La Norme)
GDPR-Art32	<code>rdf:type</code>	<code>skos:Concept</code>
GDPR-Art32	<code>skos:prefLabel</code>	"RGPD Article 32 : Sécurité du traitement"
GDPR-Art32	<code>rdfs:seeAlso</code>	Lien officiel EUR-Lex

4. Comment confronte-t-on cette règle à l'ABox ?

L'agent gardien (*Compliance Steward Agent*) effectue une passerelle logique :

- Il isole l'actif analysé (marqué en zone sécurisée TLP : RED).
- Il vérifie si les services exposés ou les vulnérabilités entrent en contradiction avec le standard de sécurité requis par le concept GDPR-Art32 (port non sécurisé, absence de chiffrement, CVE critique non patchée).

 **Principe "Green-by-Design"** : Pour éviter d'engorger la mémoire, le système n'importe pas tout le droit européen. Il extrait uniquement les triplets stricts de l'Article 32, garantissant un temps d'exécution ultra-rapide (~2 ms) et une empreinte mémoire minimale (< 85 Mo).

Restitution SOC & Conclusion

5. Visualisation dans le Dashboard Front-End

Une fois l'analyse sémantique bouclée par l'API FastAPI, le rapport de conformité remonte instantanément dans le tableau de bord de l'analyste SOC à travers un widget dédié :



Widget de Conformité RGPD & Sobriété

Portée : RGPD Article 32 (Sécurité du traitement)

Profilage Green-by-Design : Statut SUCCESS (Temps: 2.09 ms | Pic RAM: 84.93 Mo)

Échantillon Normatif : 4 triplets actifs validés en local via pySHACL.

6. Conclusion Générale

La Phase 8 démontre qu'il est possible de concilier **exigence réglementaire européenne** et **sobriété opérationnelle** (Green-by-Design). En s'appuyant sur un graphe sémantique découplé :

- L'entreprise ne subit plus la conformité comme une contrainte administrative, mais comme un flux vérifiable en temps réel.
- L'architecture conserve une légèreté d'exécution compatible avec des environnements contraints ou résidentiels.



Synthèse validée : L'API est opérationnelle sur

<http://127.0.0.1:8000/api/v1/compliance/report> et s'intègre parfaitement avec le pipeline des phases précédentes.